

AI Software Company

Engineer → Sandbox → QA Implementation Blueprint & Architecture Audit

Target Repository: github.com/laknanitish2110-sudo/ai-software-company	Date: August 2026
Author: Senior AI Systems Architect	Status: Final Architectural Blueprint

EXECUTIVE AUDIT SUMMARY: The AI Software Company codebase features a robust multi-agent UI, streaming WebSockets, multi-key OpenRouter failover, and a local 19,870 n8n workflow RAG search engine. However, its generated code output is currently unverified. Adding an E2B execution sandbox, a structured QA agent, a self-repair retry loop, and a machine-verifiable Definition of Done raises the platform to empirical reliability.

PART 1 — CURRENT IMPLEMENTATION AUDIT

1. Engineer Agent Analysis

- Inputs Received:** Concatenated string in `_build_context()` (engine.py: L218-L275) containing `problem_statement`, approved outputs from CEO, BA, Researcher, Architect, `deliverable_type` (`code/workflow/hybrid`), and per-component RAG matches.
- Output Format:** Structured JSON containing `project_structure`, `setup_instructions`, `files` (array of path, content, purpose), `environment_variables`, `dependencies`, `run_commands`, `next_steps`.
- File Generation & Storage:** Written to `generated_projects/{project_id}/` on local host disk (file_generator.py: L14-L82). Triggered ONLY upon Founder approval in `orchestrator.py` (L287-L298). ZIP created immediately at `generated_projects/{project_id}.zip`.
- Capabilities & Metadata:** Generates Python, Node, React, n8n, FastAPI. Currently lacks structured, machine-readable runtime execution metadata.

2. Orchestrator State Machine Audit

- Current States:** `CREATED` → `BA_WORKING` → `BA_REVIEW` → `RESEARCH_WORKING` → `RESEARCH_REVIEW` → `ARCHITECT_WORKING` → `ARCHITECT_REVIEW` → `ENGINEER_WORKING` → `ENGINEER_REVIEW` → `PPT_WORKING` → `COMPLETED`.
- Current Approval Flow:** Approval sets `status='approved'` and moves to next role. Rejection saves feedback into `shared_memory` as `{role}_revision_feedback` and re-prompts rejected agent.

Pipeline Aspect	CURRENT Implementation	PROPOSED Implementation
Engineer Exit	Direct to <code>ENGINEER_REVIEW</code> (Human Check)	Direct to <code>SANDBOX_WORKING</code> (E2B MicroVM)

Validation Gate	Manual Human Inspection only	Automated E2B MicroVM Build/Test/Health Probe
Failure Handling	Human Rejection with Text Feedback	QA Agent Auto-Diagnosis + Fixer Patch Loop
File Generation	Generated after Human Approval	Generated after QA Empirical Verification PASS

3. Database & Storage Audit

- **Database Engine:** aiosqlite (SQLite 3) managing projects, agent_outputs, conversations, shared_memory.
- **MVP Execution Storage:** Execution logs and QA reports can be stored in shared_memory under keys sandbox_execution_attempt_{n} and qa_report_attempt_{n} without schema migration.

4. File Generator Security Audit

- **Path Traversal Risk:** file_path.lstrip('/') prevents leading slash escapes but does not prevent ../ relative path traversal. Path.resolve().is_relative_to() must be added.

PART 2 — ENGINEER → SANDBOX CONTRACT

The Architect agent outputs a machine-readable execution contract, refined by Engineer into a runtime_manifest:

```
{
  "runtime_manifest": {
    "project_type": "node_nextjs",
    "primary_language": "typescript",
    "environment": { "node_version": "20", "env_vars": { "PORT": "3000" } },
    "commands": {
      "install": "npm install --legacy-peer-deps",
      "build": "npm run build",
      "test": "npm test -- --passWithNoTests",
      "start": "npm start",
      "health_check": { "type": "http", "path": "/", "port": 3000, "expected_status": 200 }
    },
    "executable": true
  }
}
```

PART 3 — SANDBOX RUNNER DESIGN

Stage	Command	Timeout	Failure Condition	Info Captured
1. INSTALL	npm install / pip install	120s	Non-zero exit, missing pkg	stdout, stderr, missing pkgs
2. BUILD	npm run build / py_compile	60s	Syntax error, TS error	Compiler stderr, failing lines

3. TEST	npm test / pytest	60s	Assertion failure	Stack trace, failing test case
4. RUNTIME	npm start / unicorn	20s	Process crash, port error	Process exit code, startup log
5. HEALTH	curl http://localhost:{port}/	15s	HTTP 5xx, connection refused	HTTP status code, body snippet

PART 4 & 5 — EXECUTION RESULT & QA AGENT CONTRACTS

The Sandbox returns a structured JSON result to the QA Agent to prevent prompt context window bloat:

```
{
  "qa_review": {
    "status": "FAIL",
    "severity": "HIGH",
    "failed_stage": "BUILD",
    "failure_category": "MISSING_IMPORT",
    "root_cause": "page.tsx imports Button from '@components/Button' which does not exist.",
    "failing_files": ["src/app/page.tsx"],
    "repair_instructions": {
      "summary": "Create missing Button component",
      "action_items": ["Create src/components/Button.tsx with valid default export"]
    },
    "confidence_score": 0.95
  }
}
```

PART 6 — DEFINITION OF DONE (DoD)

- **Schema Extension:** Add machine-readable definition_of_done array to BA and Architect outputs (BUILD_CHECK, HEALTH_CHECK, UNIT_TEST, MANUAL_REVIEW).
- **Governance:** Generated by BA, refined by Architect, verified by QA Agent in Sandbox.

PART 7 & 8 — SELF-REPAIR LOOP & REGRESSION PROTECTION

- **Max Retry Budget:** Strictly 3 attempts.
- **Targeted Patching:** Fixer agent receives only QA repair instructions + failing file content (not full project ZIP).
- **Regression Protection:** Full rerun of all stages on each attempt. If attempt N scores lower than attempt N-1, discard attempt N and revert to previous snapshot.

PART 9 & 10 — FAILURE CLASSIFICATION & SECURITY BOUNDARY

- **Escalation Policy:** Syntax/Missing Files → Fixer Agent; Missing Dependencies/Architecture Conflicts → Architect Agent; Repeated Same Hash / Max Retries → Human Pause.
- **Security Controls:** E2B AWS Firecracker MicroVM isolation, mock API keys, 300s timeout, outgoing network IP restrictions, 2,000 char log truncation.

PART 11 & 12 — n8n ROLE & CONTEXT BLOAT MANAGEMENT

- **n8n Role:** Outside dev loop. Used solely for post-validation automation (Sheets, Drive, Slack, GitHub).
- **Context Bloat Fix:** QA receives only DoD + ExecutionResult (4KB). Fixer receives only QA instructions + failing file (10KB).

PART 13 — EXACT FILE-LEVEL CHANGE PLAN

Action	Target File Path	Key Changes & Purpose	Risk
MODIFY	backend/app/models/schemas.py	Add SANDBOX_WORKING, QA_WORKING, REPAIR_WORKING states & QA role	Low
MODIFY	backend/app/agents/prompts.py	Add QA_SYSTEM_PROMPT, update BA DoD & Engineer runtime_manifest	Low
ADD	backend/app/services/sandbox_runner.py	Create E2B Sandbox execution runner abstraction	Medium
MODIFY	backend/app/agents/engine.py	Register QA role, add run_qa_agent() and run_fixer_agent()	Medium
MODIFY	backend/app/services/orchestrator.py	Insert Sandbox -> QA -> Repair state transitions into pipeline	High
MODIFY	backend/app/services/file_generator.py	Add path traversal resolution check Path.resolve().is_relative_to()	Low

PART 14 — STATE MACHINE TRANSITION DIAGRAM

CREATED → BA_WORKING → BA_REVIEW → RESEARCH_WORKING → RESEARCH_REVIEW
→ ARCHITECT_WORKING → ARCHITECT_REVIEW → ENGINEER_WORKING (Code Generated)
→ SANDBOX_WORKING (E2B Build/Test/Health) → QA_WORKING (Diagnose Logs)
■■■ FAIL (Retries < 3) → REPAIR_WORKING (Engineer Fixer Patch) → SANDBOX_WORKING ...
■■■ PASS → ENGINEER_REVIEW → PPT_WORKING → COMPLETED

PART 15 & 16 — MVP BOUNDARY & E2B EVALUATION

- **MVP Scope:** Node.js 20 (Next.js/React) & Python 3.11 (FastAPI), 5 execution stages, E2B runner, 3 retries.
- **E2B Evaluation Score:** 9.7 / 10 (Chosen for sub-second spinup, hardware Firecracker security, simple 20-line Python SDK).

PART 17 & 18 — FINAL VERDICT & ROADMAP

Category	Items / Action Items
KEEP	FastAPI async core, WebSockets, OpenRouter 6-key failover, n8n RAG search (workflow_search.py), PPTX/DOCX generators
MODIFY	BA/Architect prompts (DoD), Engineer prompt (runtime_manifest), orchestrator.py (Sandbox/QA loop), file_generator.py (Security)
ADD	sandbox_runner.py (E2B integration), QA_SYSTEM_PROMPT, AgentRole.QA, SANDBOX_WORKING & QA_WORKING states
P0 (Must Build)	1. sandbox_runner.py 2. QA Agent & prompt 3. Orchestrator self-healing loop 4. BA/Architect DoD schema
P1 (Immediate)	Structured SQL tables for Decision & Failure memory Targeted code diff patching
P2 (Later)	Proof of Execution (PoE) Certificate DOCX/PDF export Live terminal WebSocket stream in UI
DO NOT BUILD	Executing arbitrary code inside n8n nodes Heavy Kubernetes microservices Vector DBs for simple memory

FINAL BLUEPRINT VERDICT: The proposed E2B Sandbox + QA Agent + Self-Repair loop is technically sound, highly targeted, and directly executable on the existing codebase without breaking existing features.